



中华人民共和国金融行业标准

JR/T 0316—2024

区域性股权市场跨链认证安全规范

Specifications for regional equity markets cross-chain authentication
security

2024-11-20 发布

2024-11-20 实施

中国证券监督管理委员会 发布

目 次

前言 III

引言 IV

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 密码算法要求 2

6 业务数据要求 2

 6.1 生成主体明确 2

 6.2 数据生成时间明确 3

 6.3 业务数据提取手段可靠 3

 6.4 业务数据传输安全 3

 6.5 业务数据的存储可靠 3

 6.6 数据完整性保护手段可靠 3

7 地方业务链安全要求 3

 7.1 数据操作安全 3

 7.2 身份信息安全 3

 7.3 访问控制 4

 7.4 链间访问控制 4

 7.5 共识协议 4

 7.6 智能合约 4

 7.7 稳定性 5

8 地方业务系统安全要求 5

 8.1 入侵防范 5

 8.2 恶意代码防范 5

 8.3 程序可信执行 5

 8.4 访问控制 5

 8.5 安全策略和管理制度 5

9 跨链机制要求 5

10	跨链传输信道安全要求	6
10.1	通过证券期货行业专线网络访问	6
10.2	通过 VPC 专线网络访问	6
10.3	通过 VPN 网络访问	6
10.4	对 RPC 接口增加 API 鉴权	6
10.5	IP 白名单	6
11	跨链数据安全要求	6
11.1	基本要求	6
11.2	数据访问时的要求	6
11.3	数据传输时的要求	6
11.4	智能合约调用时的要求	6
	参考文献	7

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由全国金融标准化技术委员会证券分技术委员会（SAC/TC 180/SC4）提出。

本文件由全国金融标准化技术委员会（SAC/TC 180）归口。

本文件起草单位：中国证券监督管理委员会科技监管司、中证信息技术服务有限责任公司、中证机构间报价系统股份有限公司、深圳证券通信有限公司、上海边界智能科技有限公司、北京共识数信科技有限公司、同济大学、南京大学。

本文件主要起草人：张业龙、彭枫、王亚军、王凤冬、王毛路、李宇、陈小泉、马小峰、陈莹。

引 言

区域性股权市场是服务所在省级行政区域内中小微企业的私募股权市场，是多层次资本市场体系重要组成部分，是地方扶持中小微企业政策措施的综合运用平台，也是一类地方金融组织。同时要看到，区域性股权市场也存在功能发挥不畅、地方监管制度体系不完善、业务系统多样异构、数据规范性差、业务规则不完备等问题。区块链具有数据透明、不易篡改、可追溯等技术优势，在促进数据共享、优化业务流程、降低运营成本、提升协同效率、建设可信体系等方面具有积极作用。基于监管链和地方业务链的双层架构，可以更好支持区域性股权市场企业赋能服务、业务创新并逐步实现穿透式监管。为建成物理分散、逻辑统一的区域性股权市场新型金融基础设施，有必要建立监管链与各地方业务链的跨链对接的安全技术标准。

区域性股权市场跨链认证安全规范

1 范围

本文件规定了区域性股权市场地方业务链与监管链跨链对接的安全认证技术与系统实现要求，包括密码算法要求、业务数据要求、地方业务链安全要求、地方业务系统安全要求、跨链机制要求及跨链安全要求。

本文件适用于在区域性股权市场中进行地方业务链及与地方业务链对接的地方业务系统建设或服务运营的机构。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 11457 信息技术 软件工程术语
GB/T 20518 信息安全技术 公钥基础设施 数字证书格式
GB/T 25069 信息安全技术 术语
GB/T 32905 信息安全技术 SM3密码杂凑算法
GB/T 32918 信息安全技术 SM2椭圆曲线公钥密码算法
JR/T 0184 金融分布式账本技术安全规范

3 术语和定义

GB/T 11457、GB/T 25069 界定的以及下列术语和定义适用于本文件。

3.1

跨链 cross chain

实现在区块链之间的双向信息交互、信息验证与服务调用的技术。

3.2

监管链 global regulation blockchain

以全局服务和监管为目的构建的区块链系统。

3.3

地方业务链 regional business blockchain

各地方以服务区域性股权市场业务和生态为目的构建的区块链系统。

3.4

地方业务系统 regional business system

与地方业务链对接，实现数据传输到地方业务链的业务系统。

注：地方业务系统包括区域性股权市场的业务系统等。

3.5

业务数据 business data

地方业务系统存储和处理的数据。

3.6

业务数据主体 business data owner

业务参与方直接操作生成的数据，并作为该数据所有者的个人或机构。

3.7

智能合约 smart contract

以信息化方式传播、验证或执行合同的计算机协议。

注：在分布式账本上体现为可自动执行的计算机程序。

4 缩略语

下列缩略语适用于本文件。

API：应用程序编程接口（Application Programming Interface）

ASN.1：抽象语法标记（Abstract Syntax Notation One）

ECC：椭圆曲线加密（Elliptic Curve Cryptography）

HMAC：密钥相关的哈希运算消息认证码（Hash-based Message Authentication Code）

HTTPS：超文本传输安全协议（Hypertext Transfer Protocol Secure）

IP：网际互连协议（Internet Protocol）

RPC：远程过程调用（Remote Procedure Call）

VPC：虚拟私有云网络（Virtual Private Cloud）

VPN：虚拟专用网络（Virtual Private Network）

5 密码算法要求

国产密码算法的数字证书公钥算法采用ECC算法，公钥参数采用SM2椭圆曲线公钥密码算法。证书使用ASN.1编码，证书文件以二进制或Base64格式存放。证书中应包含证书版本、序列号、颁发者、使用者主体信息、使用者公钥、有效期、证书扩展项、算法标识等信息。

国产密码算法的数字证书的公钥算法ECC算法标识、公钥参数SM2椭圆曲线公钥密码算法标识、证书签名算法标识、摘要算法标识应符合GB/T 32905、GB/T 32918、GB/T 20518等相关国家标准以及JR/T 0184等相关行业标准。

6 业务数据要求

6.1 生成主体明确

地方业务系统应在业务数据主体生成数据前,通过证件信息、数字证书等方式对业务数据主体的实名身份进行认证。

地方业务系统应采用技术手段认证业务数据主体的真实意愿性。

地方业务系统应对上述认证结果留痕,并采用技术手段对留痕信息防泄漏、防篡改。

6.2 数据生成时间明确

业务数据生成的时间应明确。

应对获取业务数据时间的操作进行日志留痕。留痕的日志信息应采取防篡改、防灭失等技术保护手段。

6.3 业务数据提取手段可靠

业务数据提取手段应可靠,通过采集的数据包内容应第一时间进行固化,采取数字签名、时间戳、数字摘要、区块链等技术手段进行完整性保护,修改后可被发现。

6.4 业务数据传输安全

应采取加密算法确保业务数据的机密性,加密算法应采用国产密码算法,密钥协商、密钥保护手段应安全,应使用通过密码产品认证的产品。

应采取数字摘要、数字签名、HMAC等密码技术确保业务数据传输的完整性,密码算法应采用国产密码算法。

6.5 业务数据的存储可靠

应确保业务数据存储的可靠性。应提供安全、可靠的存储环境,并具备备份、容灾技术手段和运维能力以及运维制度。

业务数据的保存时限不低于60个月。对于有特殊要求或规定的,从其规定。

业务数据应支持结构化和非结构化数据类型。

应采取电子签名、区块链、数字摘要等技术手段确保业务数据完整性。对相关数据进行修改后,应能发现。

应具备健全的信息安全保护制度、内部人员安全管理制度,确保不泄露。

6.6 数据完整性保护手段可靠

业务数据完整性保护手段应可靠,可通过技术手段验证业务数据的生成主体身份、生成时间、操作的规范性、数据的完整性。

7 地方业务链安全要求

7.1 数据操作安全

地方业务链应具备查询区块平均生成时间、总区块数以及指定区块中事务明细的功能。通过使用这些功能,应能获得一致、可靠的链上数据。

7.2 身份信息安全

地方业务链应能确保用户身份标识唯一性和可鉴别性。

地方业务链的校验鉴别信息应具有加密算法和数字签名的安全机制，确保区块链中不存在重复身份标识、身份鉴别信息不被冒用。

地方业务链应具有身份认证失败处理机制。

7.3 访问控制

7.3.1 访问控制功能

地方业务链应具有访问控制功能，依据安全策略控制用户对数据的访问。

7.3.2 访问控制覆盖范围

地方业务链访问控制的覆盖范围应包括：区块链访问相关的主体、区块链访问相关的客体以及区块链访问相关资源之间的操作。

7.3.3 访问控制策略和权限

地方业务链应用应由授权主体配置访问控制策略，并按照权限最小化、相互制约原则，为账户分配访问权限。

7.4 链间访问控制

7.4.1 链间访问控制功能

地方业务链应具有访问控制功能，依据安全策略控制其他区块链系统对本区块链数据的访问。

7.4.2 链间访问控制覆盖范围

地方业务链的链间访问控制的覆盖范围应包括：其他区块链系统对本区块链访问相关的主体、区块链访问相关的客体以及区块链访问相关资源之间的操作。

7.4.3 访问控制策略和权限

地方业务链应用应由授权主体配置其他区块链的访问控制策略，并按照权限最小化、相互制约原则，为账户分配访问权限。

7.5 共识协议

地方业务链需要采用合适的共识算法确保链上数据的一致性，支持多节点参与共识和验证，具备容错性。

地方业务链的节点不可全部部署到某一机构的服务器或单一云平台服务器上。

地方业务链应确保节点数据的一致性、可靠性和可拓展性。

7.6 智能合约

7.6.1 智能合约执行

地方业务链的智能合约的执行结果应明确，可通过逻辑推理得出与实际结果一致的执行结果。

7.6.2 查询支持

地方业务链的智能合约应支持索引、区间、历史查询等功能。

7.6.3 智能合约更新

地方业务链的智能合约应具有动态更新的功能；更新过程前后，地方业务链应运行稳定。

7.6.4 合约的冻结或终止

地方业务链的智能合约应具有冻结或终止功能。

7.7 稳定性

地方业务链应运行稳定，在始终有未确认交易的场景下，地方业务链仍能平稳运行。

注：交易是区块链上的一次原子性账本数据状态变更及其过程和结果记录。

8 地方业务系统安全要求

8.1 入侵防范

地方业务系统应能在关键网络节点处检测、防止或限制内外部发起的网络攻击行为；当检测到攻击行为时，地方业务系统应记录攻击信息，包括源网络地址、攻击类型、攻击范围、攻击时间。

8.2 恶意代码防范

地方业务系统应能检测并清除恶意代码，同时应维护对恶意代码的防护机制、升级和更新。

8.3 程序可信执行

地方业务系统应具备可信验证机制，对系统程序、应用程序和重要配置文件或参数进行可信执行验证。地方业务系统应在检测到其完整性受到破坏时采取恢复措施。

8.4 访问控制

地方业务系统应做好用户访问控制管理，应对登录的用户分配相应的账户和权限。

地方业务系统的权限管理应遵从最小权限原则。

地方业务系统的访问控制粒度应达到主体为用户级，客体为文件、数据库表级、记录或字段级。

8.5 安全策略和管理制度

应制定信息安全工作的总体方针和安全策略，说明机构安全工作的总体目标、范围、原则和安全框架。

应对安全管理活动中的各类管理内容建立安全管理制度。

应对管理人员或操作人员执行的日常管理操作建立操作规程。

应形成由安全策略、管理制度、操作规程、记录表单等构成的全面的信息安全管理制度体系。

9 跨链机制要求

地方业务链和监管链跨链对接应采用公证人机制技术、哈希锁定技术、侧链技术、中继技术或其他安全的跨链技术。应提供跨链消息的输入、输出口径和真实性证明，跨链消息的有效路由；应构建跨链

消息的统一格式，定义消息来源和去处以及消息的内容，跨链消息验证，以保障跨链之后的结果安全可信。

10 跨链传输信道安全要求

10.1 通过证券期货行业专线网络访问

地方业务链与监管链通过证券期货行业专线网络进行通信。

10.2 通过 VPC 专线网络访问

在监管链和地方业务链之间建立专线，地方业务链与监管链通过专线进行通信。

10.3 通过 VPN 网络访问

在监管链和地方业务链之间建立VPN连接，监管链通过地方业务链局域网地址调用地方业务链RPC接口，此方式下通过互联网传输加密后的数据。

10.4 对 RPC 接口增加 API 鉴权

在地方业务链节点之上增加网关等鉴权服务，用于地方业务链RPC接口鉴权。监管链通过HTTPS方式访问鉴权服务，鉴权服务验证用户身份通过后，可转发到地方业务链RPC接口，鉴权服务只对调用者身份进行识别，不对接口返回数据进行任何修改。

10.5 IP 白名单

地方业务链应具备IP白名单机制，限制访问节点RPC接口IP。

11 跨链数据安全要求

11.1 基本要求

地方业务链和监管链跨链对接时，应保证数据传输的安全性与可靠性，所访问的数据，在地方链及监管链上的数据结果应确保一致。

11.2 数据访问时的要求

在监管链访问地方业务链数据时，应当完成数据校验，保障所传输的数据一致。

11.3 数据传输时的要求

在地方业务链向监管链传输数据时，应在传输完成后，进行数据完整性一致性的检查，保障所传输的数据一致。

11.4 智能合约调用时的要求

需要检验智能合约调用时的数据，以及智能合约返回的数据。保障跨链调用智能合约的结果，与本地调用时的结果一致。

参 考 文 献

- [1] 《中华人民共和国电子签名法》
-